codigo.c
C 26.59KB

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Found 9 web pages

Este arquivo é **malware**, especificamente um backdoor de Linux conhecido como **BPFDoor** (também chamado de **JustForFun**). [1] [3] [6]

A seguir está a análise passo a passo das características maliciosas evidentes no código:

1. Ocultação e Persistência (Masquerading & Persistence)

- **Falsificação de nome de processo**: O código define nomes como `/sbin/udevd -d`, `dbus-daemon --system`, `avahi-daemon` e outros que imitam processos normais do sistema. Através da função `set_proc_name`, ele sobrescreve `argv[0]`, fazendo com que ferramentas como `ps` vejam esses nomes de daemons comuns, ocultando sua verdadeira identidade. [2] [3]
- **Arquivo de bloqueio**: Utiliza o caminho `/var/run/haldrund.pid` para garantir que apenas uma instância do malware seja executada no sistema. [3]
- **Modificação de timestamp**: A função `setup_time` altera o tempo de acesso e modificação do arquivo para uma data fixa (2008), com o objetivo de evitar detecção baseada em tempo. [3]

2. Comunicação Oculta (Traffic Signaling / Backdoor)

- **Socket bruto e filtro BPF**: O código cria um socket `PF_PACKET` bruto e anexa um filtro Berkeley Packet Filter (BPF) extremamente complexo. Este filtro faz com que o backdoor "escute" passivamente pacotes TCP, UDP ou ICMP que contenham uma "sequência mágica" específica (Magic Bytes) na rede, sem ocupar portas, contornando assim firewalls. [3] [6]
- **Ativação por pacote mágico**: Quando um pacote de ativação correspondente é recebido, o malware analisa o endereço IP e a porta dentro dele, e então bifurca um processo para estabelecer conexão reversa ou iniciar um shell.

3. Mecanismo de Autenticação e Criptografia

- **Senha codificada**: No código, `hash` e `hash2` são definidos respectivamente como `"justforfun"` e `"socket"`. O atacante deve fornecer a senha correspondente para ativar diferentes modos do backdoor. [7]
- **Criptografia RC4**: O código implementa o algoritmo de criptografia RC4 para cifrar o tráfego do shell, garantindo que os comandos e a saída não sejam detectados por inspeção de tráfego. [3]

4. Manipulação de Firewall e Shell Reverso

- **Contorno de firewall**: A função `getshell` executa comandos `iptables` (construídos através de arrays de caracteres ofuscados) para adicionar regras em `PREROUTING` e `INPUT`, redirecionando o tráfego do atacante para uma porta alta aberta localmente (a faixa de portas 42391-43391), realizando assim um shell reverso que contorna restrições de firewall. [3]
- **Ocultação de histórico**: Ao iniciar o shell, as variáveis de ambiente são configuradas com `HISTFILE=/dev/null` e `MYSQL_HISTFILE=/dev/null`, impedindo que as operações do atacante sejam registradas no histórico. [3]

Conclusão

A combinação das características acima (falsificação de processo, ativação por pacote mágico BPF, criptografia RC4, manipulação de iptables, shell reverso) é consistente com o comportamento típico do **BPFDoor**, um backdoor passivo de nível APT amplamente utilizado para espionagem cibernética de longo prazo, visando principalmente servidores Linux em operadoras de telecomunicações e ambientes de nuvem. **Recomenda-se o tratamento imediato como ameaça maliciosa e a realização de análise forense e limpeza.** [1] [6]

9 web pages

Qual é a categoria principal deste malware?

Found 14 web pages

A categoria principal deste arquivo é **Backdoor (porta dos fundos)**, mais especificamente um **Backdoor Linux passivo de longo prazo**.

A seguir estão as classificações específicas e fundamentações:

1. **Classificação oficial**: A base de dados de conhecimento de táticas adversárias MITRE ATT&CK o classifica explicitamente como **Software malicioso (MALWARE)**, tipo **Backdoor**, número de identificação S1161. [3]
2. **Características comportamentais**: Ele não abre portas de escuta tradicionais, mas sim "espreita" passivamente pacotes de "ativação" (Magic Packets) na rede através do Mecanismo de Filtro de Pacotes Berkeley (BPF) do kernel. Ao receber instruções específicas, ele ativa e abre um shell reverso ou shell vinculado, sendo uma ferramenta típica de acesso persistente oculto. [1] [3]
3. **Finalidade de uso**: É comumente utilizado por grupos de APT (ameaças persistentes avançadas) para espionagem cibernética de longo prazo, visando principalmente servidores Linux em setores como telecomunicações, finanças e governo. [1] [2]

14 web pages